Project

In my current role, I have been assigned the task of implementing a web service product for one of our e-commerce customers, while ensuring adherence to security best practices based on NIST 800-53 and ISO-27001 security controls. This new service will be replacing an internally-built prototype in a legacy environment.

Architecture Description

The following project-Xpress architecture enforces authentication for all users, including customers, developers, and automated pipelines. All communication is secured using TLS to protect data in transit. Data at rest in the database and object storage is encrypted to prevent unauthorized access. The API layer ensures data integrity through validation, hashing, and controlled transactions. These measures provide a secure and reliable system for handling sensitive e-commerce operations.

Secure E-commerce Architecture Diagram

Fig 1.0

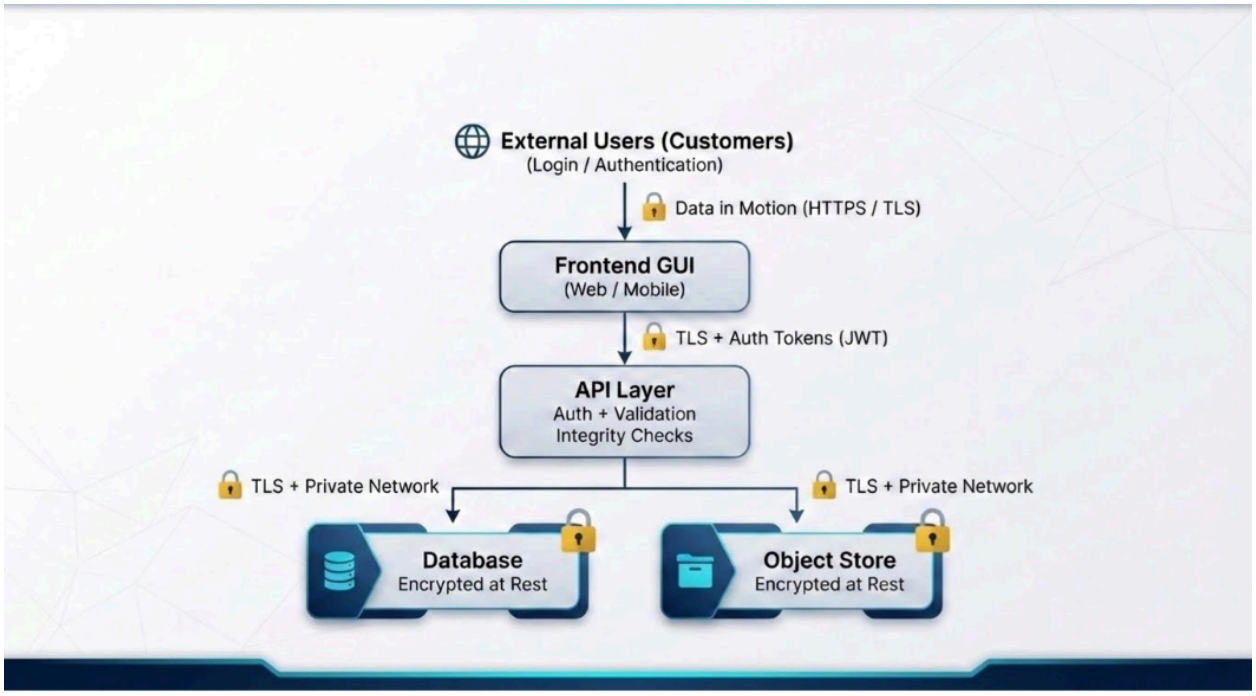


Fig 2.0

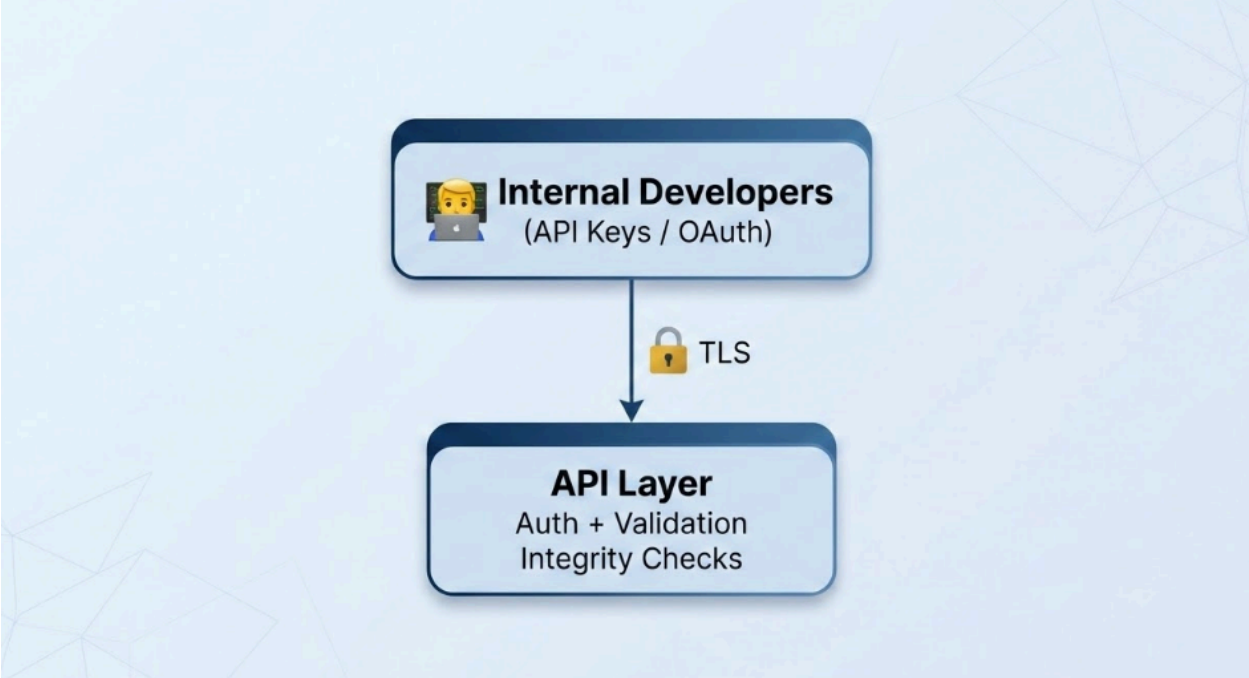
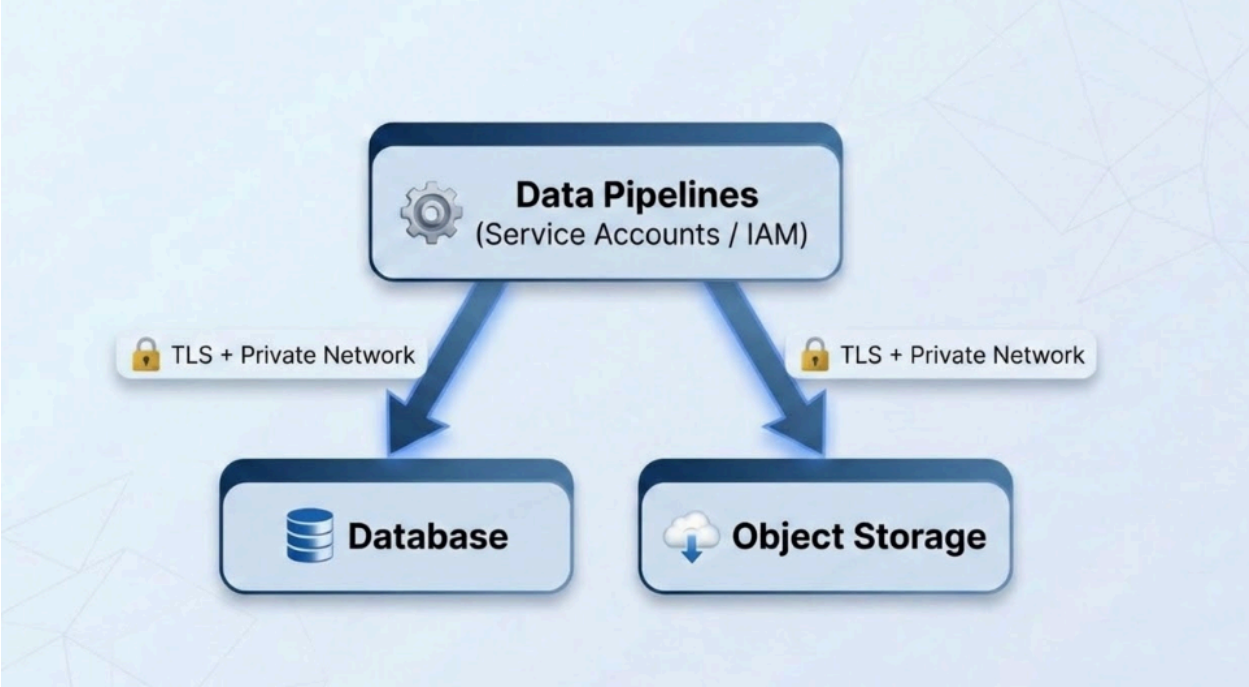

Internal Developers
(API Keys / OAuth)
TLS
API Layer
Auth + Validation
Integrity Checks

Fig 3.0


Data Pipelines
(Service Accounts / IAM)
TLS + Private Network
TLS + Private Network
Database
Object Storage

The project-Xpress architecture diagram shown in the above **fig 1, 2 and 3** depicts authentication for all users, including customers, developers, and automated pipelines. All communication is secured using TLS to protect data in transit. Data at rest in the database and object storage is encrypted to prevent unauthorized access. The API layer ensures data integrity through validation, hashing, and controlled transactions. Together, these measures provide a secure and reliable system for handling sensitive e-commerce operations.

Where Security Comes into Play:

1. **Authentication**
   - Customers: login (email/password, OAuth, JWT tokens)
   - Developers: API keys or OAuth tokens
   - Pipelines: IAM roles / service accounts

The above security measures is to ensure only authorized users access the system

2. **Transport Security (Data in Motion)**
   All communication uses HTTPS (TLS encryption) to protect data between:
   - Frontend ↔ API
   - API ↔ Database/Storage
   - Pipelines ↔ Backend

The above security measures is to prevent eavesdropping and man-in-the-middle attacks

3. **Storage Security (Data at Rest)**
   - Database and object storage encrypted (e.g. via Cloud encryption)
   - Sensitive data (passwords, payments) hashed or encrypted

   The above security measures is to protect data if storage is compromised

4. **Data Integrity**
   - Input validation at API layer
   - Checksums / hashing for stored files
   - Transaction controls in database (ACID properties)

The above security measures is to ensure that data is not altered or corrupted

What Each Label/Keyword/Acronym Means

1. TLS (HTTPS) → Protects data in motion (in transit)
2. JWT → RFC Compliant JSON Web Token
3. Authentication → Verifies identity (login, API keys, IAM roles)
4. Integrity Checks → Ensures data is not altered (validation, hashing)
5. Encrypted at Rest → Protects stored data
6. Encrypted at Motion → Protects data in Motion
7. ACID → Atomicity, Consistency, Isolation and Durability

TRADE- OFFS

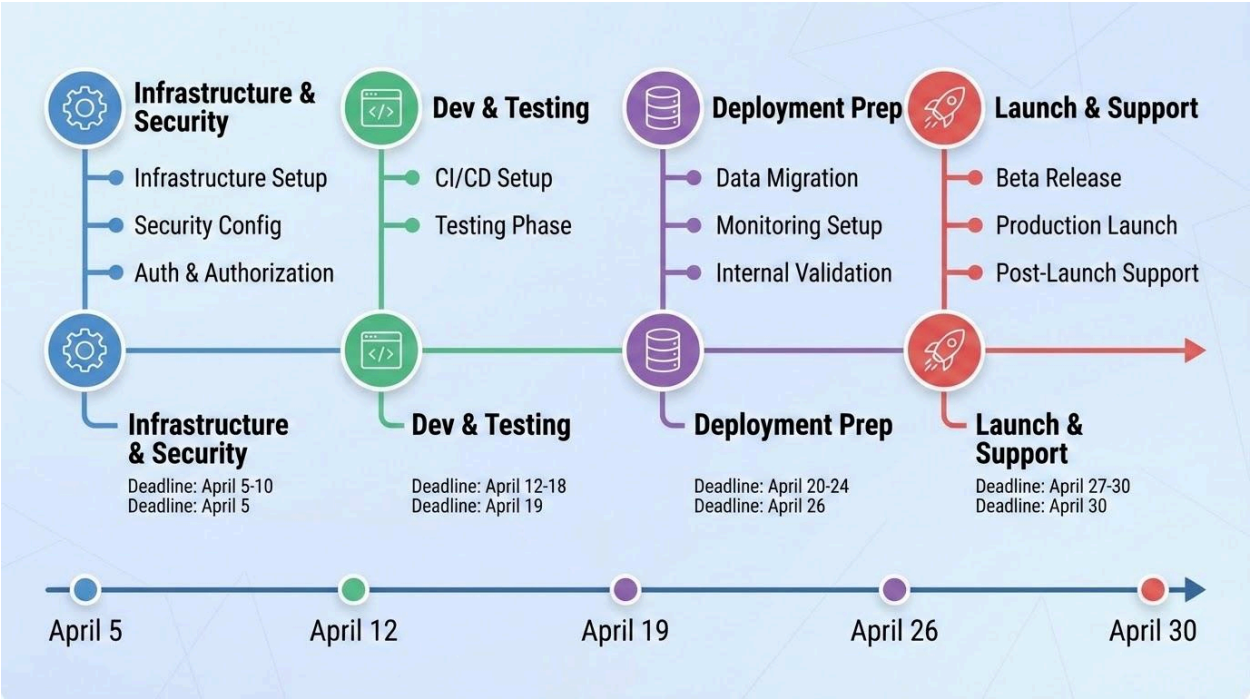
The e-commerce system prioritizes security and data integrity through authentication, encryption, and validation, while balancing performance and user convenience to ensure a safe, reliable, and user-friendly experience.

IMPLEMENTATION PLAN

Timeline Goal: Production Launch by April 30, 2026

Task Name	Description	Deadline
Infrastructure Setup	Provision cloud resources, networking, load balancers, DNS	April 5, 2026
Security Configuration	Configure TLS, encryption at rest, IAM roles, secrets management	April 8, 2026
Authentication & Authorization	Implement JWT/OAuth, RBAC, service accounts	April 10, 2026
CI/CD Pipeline Setup	Set up automated deployments, staging/prod environments, rollback strategy	April 12, 2026
Testing Phase	Unit, integration, security, and performance testing	April 18, 2026
Data Migration	Migrate and validate data, perform backups	April 20, 2026
Monitoring & Logging Setup	Configure logging, monitoring tools, and alerts	April 22, 2026
Internal Validation (Staging)	Deploy to staging, internal testing, bug fixes	April 24, 2026
Beta Release	Release to beta users, monitor feedback and performance	April 27, 2026
Production Launch	Go live, switch DNS, enable full access	April 30, 2026
Post-Launch Support	Monitor system, fix bugs, optimize performance	April 30, 2026

Fig 4.0



Documentation:
https://github.com/isaacdev001/project-Xpress/upload